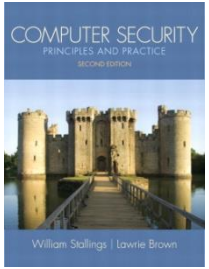
אבטחת סייבר

(אבטחת מידע/מחשבים/מערכות ממוחשבות/...)



המצגת הינה לשימוש פנימי בלבד

אין לצלם או לעשות שימוש שלא במסגרת הקורס

בקרת כניסה

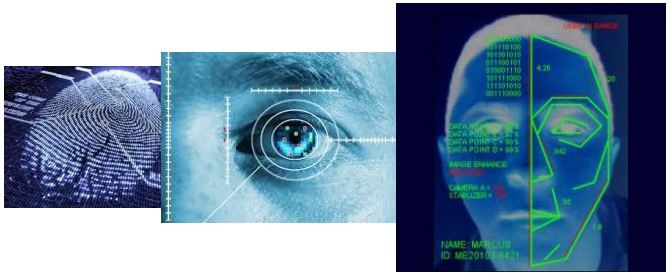
User Authentication

- fundamental security building block
  - basis of access control & user accountability
- is the process of verifying an identity claimed by or for a system entity
- has two steps:
  - identification - specify identifier
  - verification - bind entity (person) and identifier
- distinct from message authentication

User Authentication

- Something you know
  - password, PIN, answers to prearranged questions
- Something you have
  - smartcard, electronic keycard, physical key
- Something you are (static)
  - Fingerprint, retina, face
- Something you do (dynamic)
  - voice pattern, handwriting, typing rhythm (ABV- Activity-based Verification)

can use alone or combined
(multi factor authentication)
all can provide user authentication
all have issues



What You Know

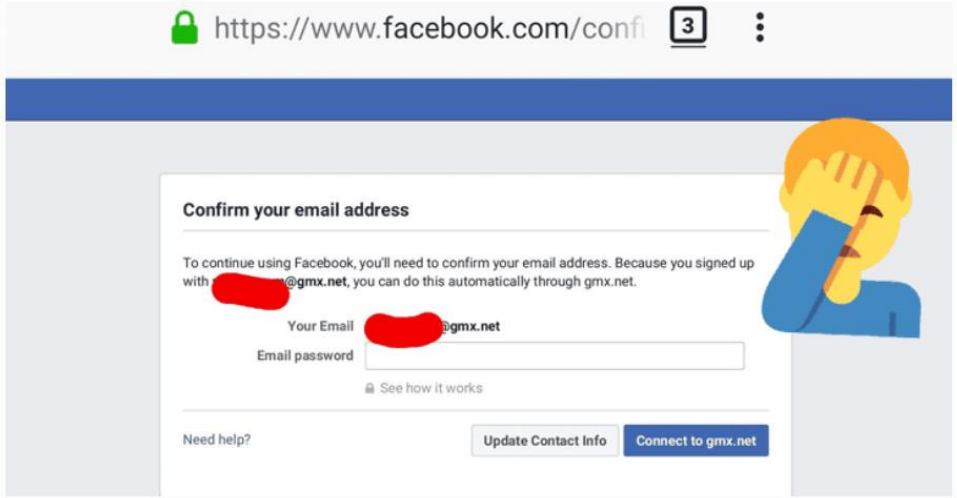
מידע סודי אותו המשתמש זוכר

- דוגמאות
  - סיסמא
    - לרוב נבחרת ע"י המשתמש
    - מורכבת מאותיות, ספרות ומסימנים מיוחדים
  - Personal Identification Number
    - בקיצור PIN
    - מספר אקראי שמוגרל ע"י המערכת
- חסרונות
  - בדר"כ הוא מוגבל מאד באורך ובאקראיות
  - אדם יכול לספר הסוד לאחר
    - מרצון או תוך אילוץ בכוח

Not just phishing...

פייסבוק מבקשת ממשתמשים סיסמאות לחשבונות האימייל שלהם

חברת פייסבוק נתפסה מבקשת ממשתמשים להזין את הסיסמא לחשבון האימייל בו השתמשו בעת הרישום, לטענתם, ע"מ לבצע "אימות אוטומטי". ככל הנראה, בקשה זו מופיעה רק כאשר בתהליך הרישום משתמשים בכתובת אימייל שנראית לחברת פייסבוק חשודה.



What You Have

יחידה פיסית שנמצאת ברשות המשתמש

- דוגמאות
  - תעודת זהות
  - כרטיס אשראי
  - כרטיס סטודנט
  - GSM SIM
  - Smart Card שמכיל מפתח פרטי
- היתרונות בקיום יחידה פיסית
  - ניתן לאחסן אינפורמציה ארוכה ואקראית
    - תלוי במגבלות היחידה
  - איתור אובדן
    - במקרים מסוימים ניתן לעקוב אחר יחידות פיסיות שנגנבו
  - שיכפול וקריאת המידע הסודי
    - קלים, קשים או קשים מאד לביצוע, תלוי בסוג היחידה.
      - אך אפשריים תוך שימוש בציוד ייחודי או תוך השקעה גדולה במיוחד
- חסרונות
  - יכול להיגנב או להיאבד

What You Are

ביומטריה

- למשל
  - סריקת רשתית העין
  - טביעת אצבע
  - זיהוי קול
  - צילום פנים או "טביעת חום" של הפנים
  - תמונה

- שיטות אלו הן יחסית מוצלחות מול משתמש תמים
  - אבל ניתן "לעבוד" על גלאים שכאלה, לא בקושי רב
  - ולכן הן לא מגנות נגד תוקפים מכוונים
  - ובניגוד למקרים הקודמים
    - אפשר "לגנוב" ביומטריה בלי ידיעת בעליה
- לדוגמא
  - אפשר לייצר טביעות על אצבעות גומי, העוברות את מכשירי הביומטריה בהסתברות הצלחה טובה, במחיר אפסי

אימות כפול

Two-Factor Authentication

- כפי שראינו, אף אחת משלושת השיטות אינה מספקת אמינות מוחלטת
- לכן במערכות רבות דורשים אימות כפול
  - אימות שמסתמך על שניים מתוך שלושת סוגי האימות
    - בדרך כלל What you know ו-What you have
  - או אפילו אימות משולש
- לדוגמא
  - כרטיס אשראי בכספומט – עם מספר סודי
  - SecurID – כרטיס + מספר סודי
  - תעודת זהות ביומטרית : כרטיס + טביעת אצבע

Password Authentication

- widely used user authentication method
  - user provides name/login and password
  - system compares password with that saved for specified login

- authenticates ID of user logging and
  - that the user is authorized to access system
  - determines the user's privileges
  - is used in discretionary access control

Authentication Using Passwords

```
LOGIN: ken
PASSWORD: FooBar
SUCCESSFUL LOGIN
```

(a)

```
LOGIN: carol
INVALID LOGIN NAME
LOGIN:
```

(b)

```
LOGIN: carol
PASSWORD: Idunno
INVALID LOGIN
LOGIN:
```

(c)

(a) A successful login

(b) Login rejected after name entered

(c) Login rejected after name and password typed

Authentication Using Passwords

LBL> telnet elxsi
ELXSI AT LBL
LOGIN: root
PASSWORD: root
INCORRECT PASSWORD, TRY AGAIN
LOGIN: guest
PASSWORD: guest
INCORRECT PASSWORD, TRY AGAIN
LOGIN: uucp
PASSWORD: uucp
WELCOME TO THE ELXSI COMPUTER AT LBL

- How a cracker broke into LBL (a U.S. Dept. of Energy research lab)
  - The uucp (UNIX to UNIX Copy Program) account is used for intermachine network traffic and has superuser power, so the cracker was now in a U.S. Dept. of Energy machine as superuser

Authentication – Guidelines for Selecting Passwords

- Use characters other then A-Z
- Choose long passwords (>6)
- Avoid actual names or words (about 150,000 words of ≥6 in English)
- Choose unlikely passwords (control char, digits, etc.)
- Change passwords regularly
- Don’t write down; Don’t tell anyone…

Password Vulnerabilities

- offline dictionary attack
- specific account attack
- popular password attack
- password guessing against single user
- workstation hijacking
- exploiting user mistakes
- exploiting multiple password use
- electronic monitoring

Countermeasures

- stop unauthorized access to password file
- intrusion detection measures
- account lockout mechanisms
- policies against using common passwords but rather hard to guess passwords
- training & enforcement of policies
- automatic workstation logout
- encrypted network links

Authentication Using Passwords

Bobbie, 4238, e(Dog4238)
Tony, 2918, e(6%%TaeFF2918)
Laura, 6902, e(Shakespeare6902)
Mark, 1694, e(XaB@Bwcz1694)
Deborah, 1092, e(LordByron,1092)

Salt Password

The use of salt to defeat pre-computation of encrypted passwords

UNIX Implementation

- original scheme
  - 8 character password form 56-bit key
  - 12-bit salt used to modify DES encryption into a one-way hash function
  - 0 value repeatedly encrypted 25 times
  - output translated to 11 character sequence
- now regarded as woefully insecure
  - e.g. supercomputer, 50 million tests, 80 min
- sometimes still used for compatibility

Password Cracking

- dictionary attacks
  - try each word then obvious variants in large dictionary against hash in password file
- rainbow table attacks
  - precompute tables of hash values for all salts
  - a mammoth table of hash values
  - e.g. 1.4GB table cracks 99.9% of alphanumeric Windows passwords in 13.8 secs
  - not feasible if larger salt values used

Password Choices

- users may pick short passwords
  - e.g. 3% were 3 chars or less, easily guessed
  - system can reject choices that are too short
- users may pick guessable passwords
  - so crackers use lists of likely passwords
  - e.g. one study of 14000 encrypted passwords guessed nearly 1/4 of them
  - would take about 1 hour on fastest systems to compute all variants, and only need 1 break!

התקפת מילון

Dictionary Attack

- מטרת ההתקפה
  - מציאת סיסמת המשתמש (password)
- הקלט
  - תוצאת תימצות של הסיסמא ופרמטרים ידועים נוספים
- ההתקפה מסתמכת על כך שרוב הסיסמאות שמשתמשים בוחרים הן "סיסמאות חלשות"
  - מילים מהמילון, צירופי מילים ומספרים או סיסמאות קלות
    - למשל 12345678, Yossi123, ILoveYou
  - כדי למצוא סיסמא מספיק לבדוק סיסמאות חלשות
    - מה שמקטין את גודל מרחב הסיסמאות במידה ניכרת
- זהו מעין חיפוש ממצה שמבוצע רק על סיסמאות "שכיחות"

התקפת מילון לא מקוונת

- במהלך הקורס נפריד בין שני מקרים בהם התקפת מילון מבוצעת ב-Offline
  - כאשר קובץ הסיסמאות נחשף
  - כאשר ברשות התוקף רק מידע (תמצית) שנשלח ברשת
- כאשר נדון בהתקפת מילון נתייחס לרוב לאופציה השנייה
  - הדורשת מהתוקף פחות מאמץ להשיג את המידע הנדרש
- כמו כן, שימו לב כי לא ניתן לבצע התקפת מילון על מפתחות קריפטוגרפיים
  - אם הם נוצרו בדרך בטוחה, ונבחרו באקראי

כיצד מבצעים התקפת מילון

- נניח כי המתקיף השיג מחרוזת y כך ש-
  - y=f(password), או y=f(password, x)
    - ובנוסף x ידוע לתוקף
    - נניח גם ש-f() ידועה לתוקף
    - הנחה הנגזרת מעקרון קרכהופס

- המתקיף יכול לעבור על מילון שמכיל את מרחב כל הסיסמאות החלשות ולבדוק עבור כל w שמופיעה במילון האם y=f(w) או y=f(w, x)
  - אם התשובה חיובית, אזי סביר ש-w=password
- בהינתן מספר הודעות שכאלה, ניתן למצוא את הסיסמא password בהסתברות גבוהה מאוד

התקפת מילון מקוונת

- בהתקפה מקוונת נדרש התוקף לתשאל את המערכת עבור כל ערכי המילים במילון
  - התקפה זו נקראת התקפת מילון מקוונת מכיוון שכל בדיקת מילה מהמילון דורשת התקשרות למערכת
  - התקפות מילון מקוונות פחות יעילות מהתקפות offline
- מערכות בקרת כניסה נדרשות לזהות ניסיונות להתקפת מילון מקוונת
  - ולחסום את חשבון המשתמש שאת הסיסמא שלו מנסה התוקף לחשוף
    - למשל אחרי 5 ניסיונות
    - מגוון מערכות מבצעות האטת קצב אחרי 3 ניסיונות שגויים (כגון sleep לזמן מה בין ניסיון שגוי לבא אחריו), וחסימה מוחלטת אחרי עוד מספר ניסיונות שגויים

התקפת מילון מקוונת – דוגמא

WIRED

Weak Password Brings 'Happiness' to Twitter Hacker

By Kim Zetter January 6, 2009 | 4:35 pm | Categories: Crime

An 18-year-old hacker with a history of celebrity pranks has admitted to Monday's hijacking of multiple high-profile Twitter accounts, including President-Elect Barack Obama's, and the official feed for Fox News.

The hacker, who goes by the handle GMZ, told Threat Level on Tuesday he gained entry to Twitter's administrative control panel by pointing an automated password-guesser at a popular user's account. The user turned out to be a member of Twitter's support staff, who'd chosen the weak password "happiness."

Cracking the site was easy, because Twitter allowed an unlimited number of rapid-fire log-in attempts.

...

The intrusion began unfolding Sunday night, when GMZ randomly targeted the Twitter account belonging to a woman identified as "Crystal." He found Crystal only because her name had popped up repeatedly as a follower on a number of Twitter feeds. "I thought she was just a really popular member," he said.

Using a tool he authored himself, he launched a dictionary attack against the account, automatically trying English words. He let the program run overnight, and when he checked the results Monday morning at around 11:00 a.m. Eastern Time, he found he was in Crystal's account.

That's when he realized that Crystal was a Twitter staffer, and he now had the ability to access any other Twitter account by simply resetting an account holder's password through the administrative panel. He also realized he hadn't used a proxy to hide his IP address, potentially making him traceable. He said he hadn't used a proxy because he didn't think the intrusion was important enough to draw law-enforcement attention, and "didn't think it would make headlines."

http://www.wired.com/threatlevel/2009/01/professed-twitt/

Proactive Password Checking

- rule enforcement plus user advice, e.g.
  - 8+ chars, upper/lower/numeric/punctuation
  - may not suffice
- password cracker
  - time and space issues
- Markov Model
  - Training using dataset of guessable passwords - use them to derive probabilities of transition
  - hence reject any password it might generate
- Bloom Filter
  - use to build table based on dictionary using multiple hash functions
  - check desired password against this table(false positives…)

Authentication – Using one-time Passwords

- Use hardware card like BGU's secur-id
- Use one-way hashing functions:

$$i = 0 \quad P_0 = f(f(\ldots(f(P)))) \quad n$$

$$i = 1 \quad P_1 = f(f(\ldots(f(P)))) \quad n-1$$

$$i = n-1 \quad P_{n-1} = f(P)$$

Only user knows P not computer!

- First try – user sends P1, computer computes P0
- Second try – user sends P2, computer computes P1. Enemy who listens cannot break it!

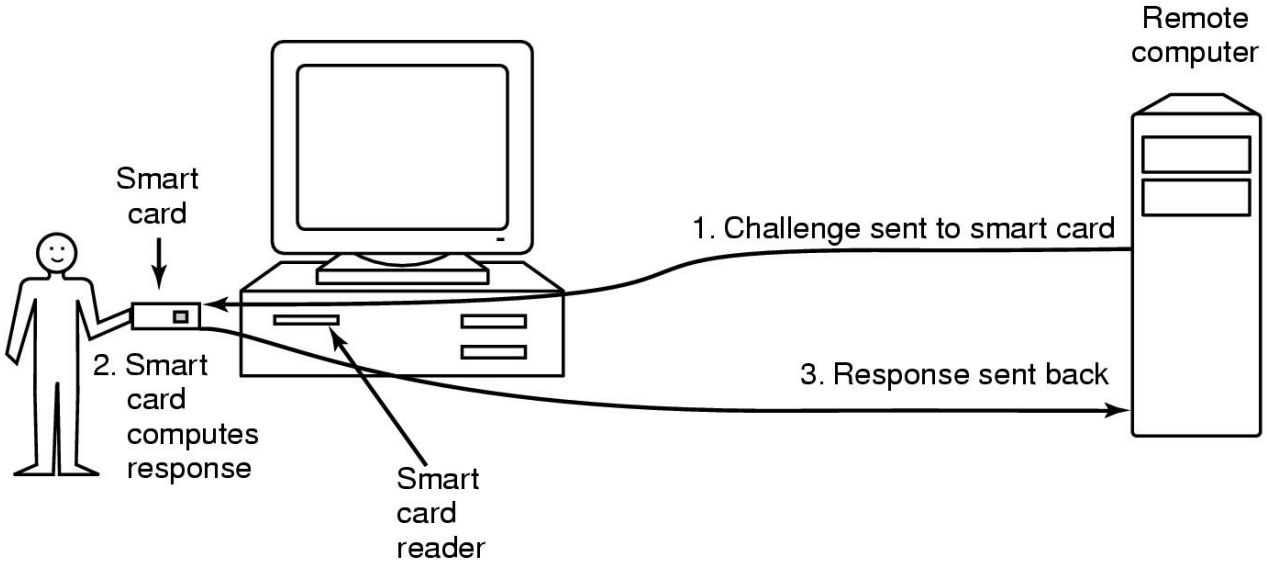
Passwords: Text vs Graphical

What You Have

יחידה פיסית שנמצאת ברשות המשתמש

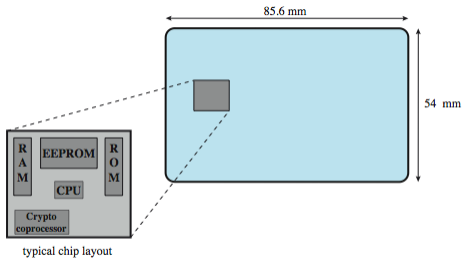
- דוגמאות
  - תעודת זהות
  - כרטיס אשראי
  - כרטיס סטודנט
  - GSM SIM
  - Smart Card שמכיל מפתח פרטי
- היתרונות בקיום יחידה פיסית
  - ניתן לאחסן אינפורמציה ארוכה ואקראית
    - תלוי במגבלות היחידה
  - איתור אובדן
    - במקרים מסוימים ניתן לעקוב אחר יחידות פיסיות שנגנבו
  - שיכפול וקריאת המידע הסודי
    - קלים, קשים או קשים מאד לביצוע, תלוי בסוג היחידה.
      - אך אפשריים תוך שימוש בציוד ייחודי או תוך השקעה גדולה במיוחד
- חסרונות
  - יכול להיגנב או להיאבד

Authentication Using a Physical Object



- Magnetic cards
  - magnetic stripe cards
  - chip cards: stored value cards, smart cards

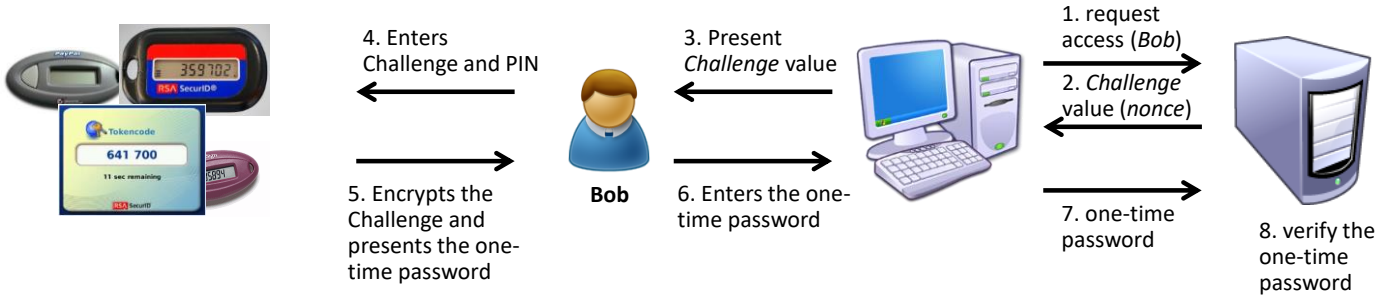
Smartcard



- credit-card like
- has own processor, memory, I/O ports
  - wired or wireless access by reader
  - may have crypto co-processor
  - ROM, EEPROM, RAM memory
- executes protocol to authenticate with reader/computer
- also have USB dongles

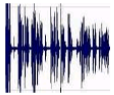
Tokens - asynchronous authentication

- Uses the challenge-response method
- Masquerading attack is possible if the token is shared or stolen
- Not vulnerable to eavesdropping, sniffing, replay, or password guessing



What You Are

ביומטריה



- למשל
  - סריקת רשתית העין
  - טביעת אצבע
  - זיהוי קול
  - צילום פנים או "טביעת חום" של הפנים
  - תמונה

- שיטות אלו הן יחסית מוצלחות מול משתמש תמים
  - אבל ניתן "לעבוד" על גלאים שכאלה, לא בקושי רב
  - ולכן הן לא מגנות נגד תוקפים מכוונים
  - ובניגוד למקרים הקודמים
    - אפשר "לגנוב" ביומטריה בלי ידיעת בעליה
- לדוגמא
  - אפשר לייצר טביעות על אצבעות גומי, העוברות את מכשירי הביומטריה בהסתברות הצלחה טובה, במחיר אפסי

Biometric Authentication

- attempts to authenticate an individual based on unique physical characteristics
- based on pattern recognition
- Is technically complex and expensive when compared to passwords and tokens

Biometric Authentication

- Face recognition
  - Measures various features in the face such as distances between eyes, nose etc.
  - Accurate but no well accepted due to privacy issues
- Fingerprint
  - Patterns on the tip of a finger
  - Sensitive to minor changes (temperature, pressure, surface damage)
  - Accurate, acceptable by the user
- Hand geometry and hand topography
  - Shape, size peaks and valleys
  - Accurate, acceptable by the user

Biometric Authentication

- Retina (רשתית)
  - Blood vessel patterns
  - Very accurate however, sensitive to physical condition (diabetes, pregnancy, heart attack); perceived as intrusive

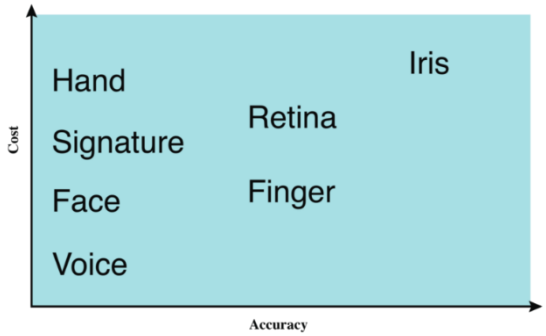
- Iris scan (קשתית)
  - Patterns in the iris
  - Very accurate however, sensitive to physical condition (diabetes, pregnancy, heart attack); perceived as intrusive

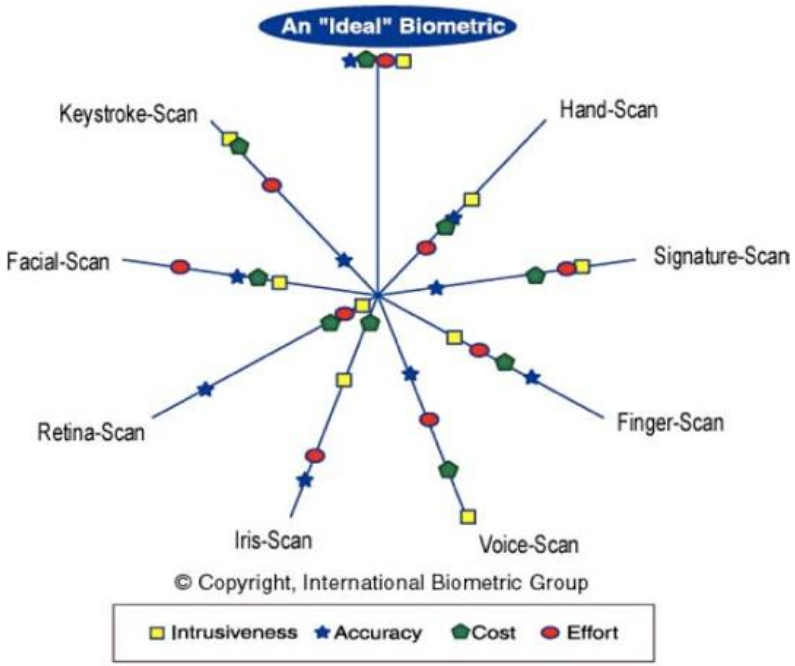
Biometric Authentication

- Voice patterns
  - Not so accurate
  - The person can be recorded; solution – use a challenge
- Keystroke dynamics
  - Dwell time; flight time
  - Accurate
  - 2-factor authentication
  - Can provide continuous verification
- Signature dynamics

Biometrics - parameters to consider

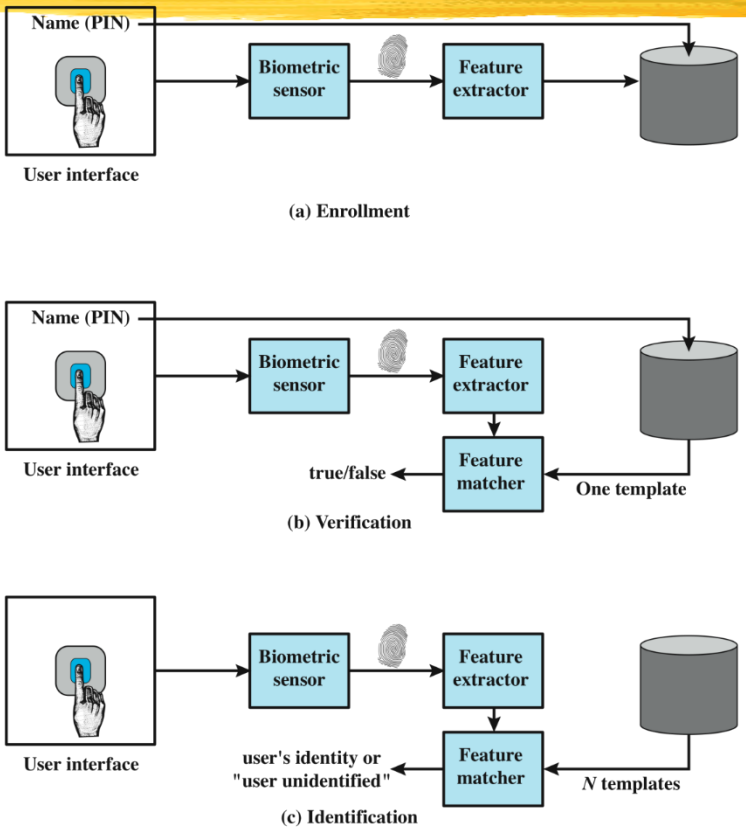
- Accuracy
- Intrusiveness
- Cost
- Time to process





Source: Zephyr Analysis

Operation of a Biometric System



Biometric Accuracy

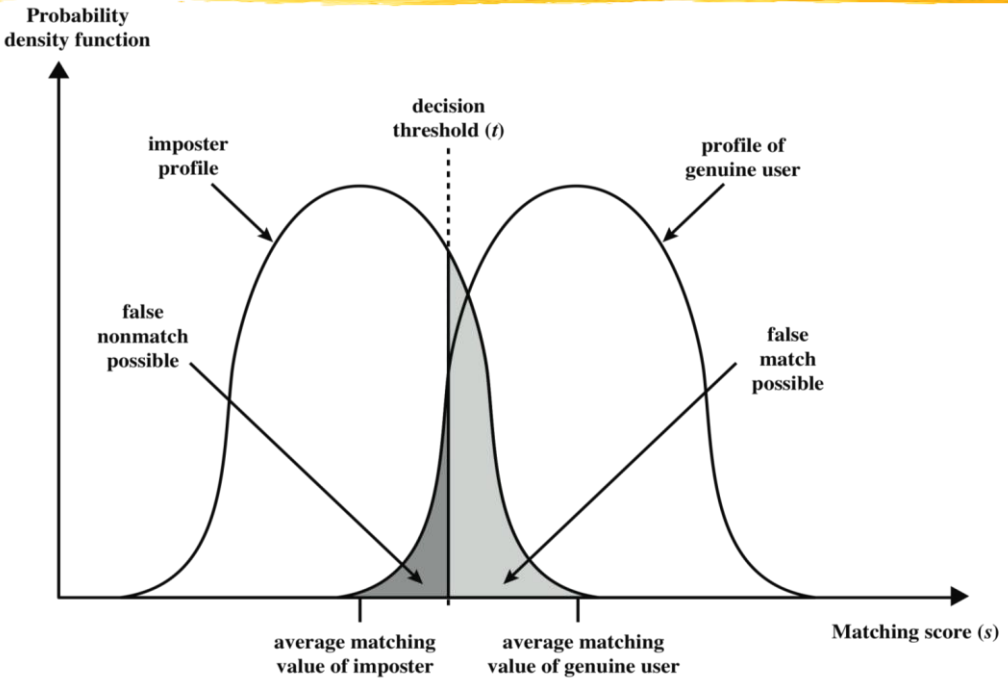
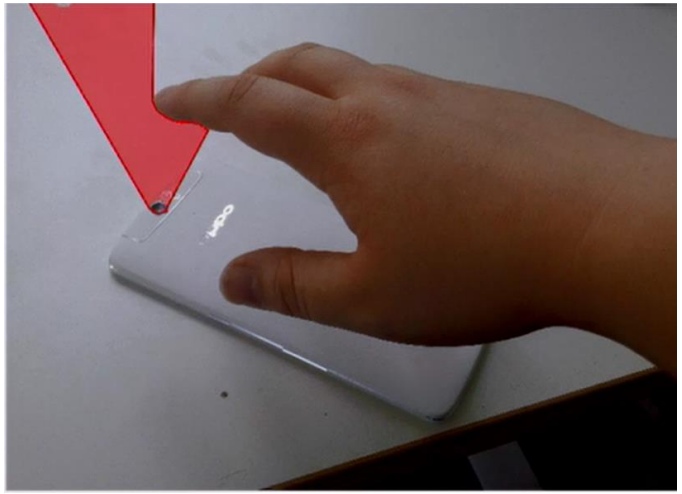
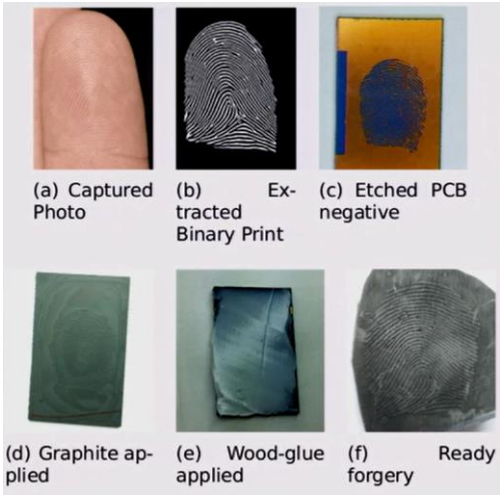


Figure 3.7 Profiles of a Biometric Characteristic of an Imposter and an Authorized Users In this depiction, the comparison between presented feature and a reference feature is reduced to a single numeric value. If the input value (s) is greater than a preassigned threshold (t), a match is declared.

BioMetrics Vulnerabilities

- In WOOT Workshop of Usenix conference 2014 held in San-Diego it was shown that using Smartphones:
- Fingerprints are not secured at all….





עוד אמצעים ביומטריים

- סריקת ורידים
- מצלמות תלת מימד
- חיישני אינפרה אדום
- ABV
- ...